

Cyber Threats and Malware

Detailed knowledge document for the CyberRAG knowledge base

1. Introduction to Cyber Threats

A cyber threat is any potential event, actor, action, or condition that can harm computers, networks, applications, users, or information. Threats may affect confidentiality, integrity, availability, privacy, finances, reputation, or normal business operations. A vulnerability is a weakness. An exploit is a method that takes advantage of a weakness. A cyberattack is an attempt to compromise, disrupt, manipulate, or gain unauthorized access to a target.

2. Major Types of Cyber Threats

Important threat categories include malware, phishing and other social engineering, password and credential attacks, denial-of-service and distributed denial-of-service attacks, web application attacks, insider threats, supply-chain compromise, misconfiguration, data breaches, and exploitation of known or zero-day vulnerabilities.

3. Malware Overview

Malware means malicious software. It is designed to perform unwanted or harmful actions such as damaging files, stealing information, spying on users, encrypting data, installing persistence, or providing unauthorized control. Major types include viruses, worms, Trojan horses, ransomware, spyware, keyloggers, rootkits, backdoors, bots, adware, scareware, fileless malware, cryptojacking malware, and logic bombs.

4. Phishing and Social Engineering

Phishing uses deception and impersonation to convince victims to reveal information, open malicious attachments, visit fraudulent websites, or perform unsafe actions. Spear phishing targets a particular person or organization. Smishing uses text messages. Vishing uses voice calls. Business email compromise abuses trusted business communications. Defenses include awareness, careful verification, email filtering, multi-factor authentication, and inspection of links and attachments.

5. Credential Attacks

Credential attacks attempt to obtain or misuse passwords, authentication tokens, or other identity information. Examples include brute-force attempts, password spraying, credential stuffing using previously exposed credentials, and phishing. Defenses include strong unique passwords, password managers, multi-factor authentication, rate limiting, account monitoring, and detection of unusual login behavior.

6. Denial-of-Service and DDoS

A denial-of-service attack attempts to make a service unavailable by exhausting resources or overwhelming it with requests. A distributed denial-of-service attack uses many systems, often compromised devices, to generate traffic. Defenses include traffic filtering, rate limiting, redundancy, content delivery infrastructure, capacity planning, and specialized DDoS mitigation.

7. Web Application Threats

Web applications may be attacked through injection flaws, cross-site scripting, broken authentication, access-control failures, insecure configuration, vulnerable components, and other design or implementation weaknesses. Important defenses include secure coding, input validation, parameterized queries, authorization checks, patching, security testing, and logging.

8. Insider and Supply-Chain Threats

An insider threat involves someone with legitimate access intentionally misusing that access or accidentally causing harm. Supply-chain attacks compromise trusted vendors, software dependencies, updates, or services. Least privilege, access reviews, logging, software inventory, dependency management, integrity checks, and supplier assessment reduce these risks.

9. Detailed Types of Malware

9.1 Computer Virus

A computer virus attaches to a host file or program and typically runs when that infected host is executed. It may modify files, damage data, or spread to other files. Endpoint protection, updates, and cautious handling of untrusted files help reduce risk.

9.2 Computer Worm

A worm is self-propagating malware that can spread through networks without attaching to a normal host program. It may exploit vulnerabilities, exposed services, or weak credentials. Patching, segmentation, firewalls, and monitoring are key defenses.

9.3 Trojan Horse

A Trojan disguises itself as legitimate or useful software. Victims may install it believing it is safe. It can steal information, install other malware, or provide unauthorized access. Downloading only from trusted sources and verifying software helps prevent infection.

9.4 Ransomware

Ransomware restricts access to files or systems, commonly through encryption, and attempts to pressure the victim into payment. Some operations also steal data and threaten publication. Strong defenses include tested backups, patching, multi-factor authentication, segmentation, endpoint monitoring, and an incident response plan.

9.5 Spyware

Spyware secretly collects information about a user or system. It may monitor activity, collect browsing data, or steal sensitive information. Endpoint security, trusted software sources, and updates reduce exposure.

9.6 Keylogger

A keylogger records keyboard input and can capture passwords and other sensitive information. It may be software-based or physical. Multi-factor authentication and endpoint monitoring provide additional protection.

9.7 Rootkit

A rootkit attempts to maintain privileged access while hiding itself or other malicious activity. Detection can be difficult because system visibility may be affected. Secure boot, patching, integrity monitoring, and trusted recovery procedures are useful defenses.

9.8 Backdoor

A backdoor is an unauthorized method of bypassing normal authentication or access controls. Attackers may use it to return to a compromised system. Monitoring, credential rotation, integrity checks, and complete remediation are important.

9.9 Bot and Botnet

A bot is an infected device that receives commands from an external controller. A botnet is a group of such devices. Botnets can be used for DDoS, spam, fraud, or other malicious activity. Patching and network monitoring help detect compromise.

9.10 Adware and Scareware

Adware displays unwanted advertising and may track users or manipulate browsers. Scareware uses alarming fake warnings to pressure users into installing software or paying for fake services. Remove untrusted software and verify warnings through trusted interfaces.

9.11 Fileless Malware

Fileless malware relies heavily on memory, legitimate system tools, or built-in scripting capabilities rather than traditional executable files. Behavior monitoring, detailed logging, least privilege, and endpoint detection can help identify it.

9.12 Cryptojacking

Cryptojacking uses a victim's computing resources for unauthorized cryptocurrency mining. Signs can include unusually high CPU or GPU usage, power consumption, and reduced performance.

9.13 Logic Bomb

A logic bomb is malicious code that activates when a specific condition is met, such as a date or system event. Code review, separation of duties, access controls, and monitoring reduce the opportunity for hidden malicious logic.

10. Key Differences

Virus: attaches to a host file and usually needs execution.

Worm: can self-propagate across systems or networks.

Trojan: relies on deception by appearing legitimate.

Ransomware: restricts access to data or systems, often through encryption.

Spyware: focuses on secretly collecting information.

Rootkit: focuses on privileged access and concealment.

11. Common Signs of Infection

Possible indicators include unusual slowdowns, high CPU or network activity, unknown processes, suspicious browser extensions, repeated crashes, unexpected security changes, unauthorized accounts, unusual login activity, unexplained file encryption, or connections to suspicious external systems. One symptom alone does not prove malware, but multiple indicators may justify investigation.

12. Prevention and Defense

1. Keep operating systems, applications, browsers, and security tools updated.
2. Use strong unique passwords and enable multi-factor authentication.
3. Maintain tested backups and protect them from unauthorized modification.
4. Apply least privilege and remove unnecessary administrator access.
5. Install software only from trusted sources.
6. Treat unexpected links, attachments, QR codes, and authentication requests cautiously.
7. Use endpoint protection and behavior monitoring.
8. Segment networks to reduce lateral movement and worm propagation.
9. Monitor authentication, process, and network activity.
10. Maintain and practice an incident response plan.

13. Responding to Suspected Malware

Follow the organization's incident response procedures. Avoid unnecessary actions that could spread the infection or destroy evidence. Isolate affected systems when appropriate, preserve relevant logs and evidence, determine scope and impact, remove malicious persistence, remediate the underlying weakness, restore from known-good sources when necessary, and monitor for recurrence.

14. Summary

Cyber threats take many forms, including malware, phishing, credential attacks, DDoS, web attacks, insider misuse, supply-chain compromise, and exploitation of vulnerabilities. Malware itself includes viruses, worms, Trojans, ransomware, spyware, keyloggers, rootkits, backdoors, bots, adware, scareware, fileless malware, cryptojacking, and logic bombs. Effective cybersecurity relies on layered defenses, secure configuration, patching, authentication, backups, monitoring, user awareness, and incident response.